

DVWA – Login Interception con Burp Suite (Web Application Security)

Corso: Cybersecurity Analyst

Modulo: W8D1 (Pratica)

Piattaforma: Epicode

Studente: Nouman Javed Nizami

Data: 11/02/2026

1. Obiettivo dell'esercizio

L'obiettivo di questo esercizio è comprendere e dimostrare il funzionamento dell'intercettazione delle richieste HTTP tramite Burp Suite, analizzando il meccanismo di login dell'applicazione vulnerabile DVWA (Damn Vulnerable Web Application). In particolare, l'attività si concentra sull'intercettazione e analisi di una richiesta POST di autenticazione con credenziali errate.

2. Ambiente di lavoro

- Sistema operativo: Kali Linux (VM)
- Web application: DVWA (Damn Vulnerable Web Application)
- Web server: Apache2
- Database: MySQL / MariaDB
- Strumento di test: Burp Suite Community Edition
- Target: <http://127.0.0.1/DVWA>

3. Procedura svolta

- 1 Avvio dei servizi necessari (Apache e MySQL) dal terminale di Kali Linux.
- 2 Accesso alla pagina di setup di DVWA e creazione/reset del database.
- 3 Accesso all'applicazione DVWA tramite credenziali di default.
- 4 Impostazione del livello di sicurezza DVWA su LOW.
- 5 Avvio di Burp Suite e configurazione del proxy con Intercept attivo.
- 6 Utilizzo del browser integrato di Burp per intercettare la richiesta di login.
- 7 Inserimento di credenziali errate e intercettazione della richiesta POST /login.php.
- 8 Analisi della richiesta HTTP (username, password, user_token).
- 9 Invio della richiesta al Repeater e analisi della risposta del server.
- 10 Verifica del messaggio di errore "Login failed" come conferma del risultato.

Di seguito sono elencate le evidenze raccolte durante l'esercizio.

Avvio servizi Apache e MySQL da terminale.

```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)-[~]  
$ sudo service apache2 start  
[sudo] password for kali:  
(kali@kali)-[~]  
$ sudo service mysql start  
(kali@kali)-[~]  
$
```

Pagina DVWA setup.php con Create / Reset Database.

Setup :: Damn Vulnerable x

http://127.0.0.1/DVWA/setup.php

Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums

Apache
Web Server SERVER_NAME: 127.0.0.1

mod_rewrite: **Not Enabled**
mod_rewrite is required for the AP labs.

PHP
PHP version: 8.4.16
PHP function display_errors: **Disabled**
PHP function display_startup_errors: **Disabled**
PHP function allow_url_include: **Enabled** - Feature deprecated in PHP 7.4, see lab for more
PHP function allow_url_fopen: **Enabled**
PHP module gd: **Installed**
PHP module mysql: **Installed**
PHP module pdo_mysql: **Installed**

Database
Backend database: MySQL/MariaDB
Database username: kali
Database password: *****
Database database: dvwa
Database host: 127.0.0.1
Database port: 3306

API
This section is only important if you want to use the API module.
Vendor files installed: **Not Installed**

For information on how to install these, see the [README](#).

Status in red, indicate there will be an issue when trying to complete some modules.

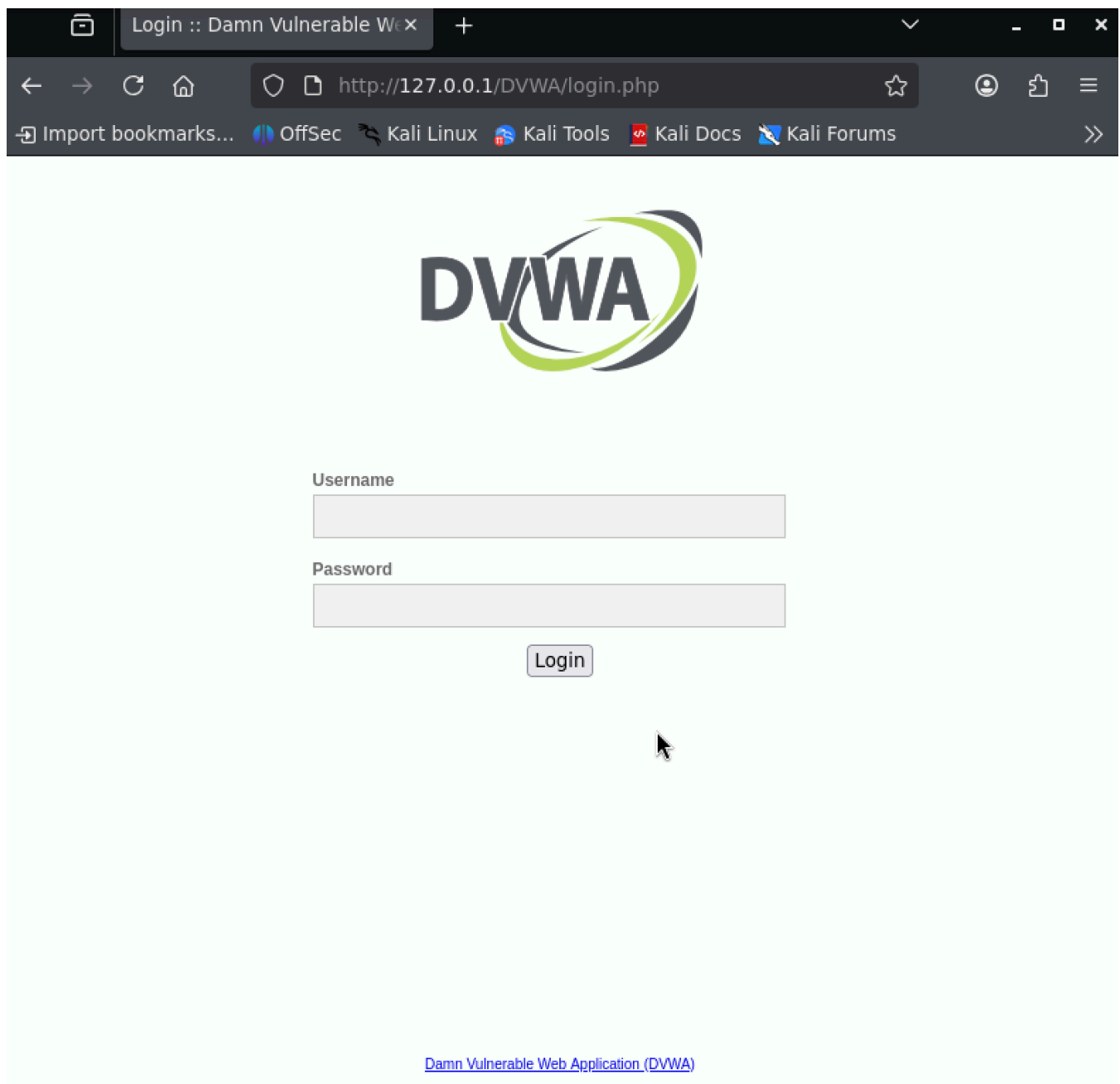
If you see disabled on either `allow_url_fopen` or `allow_url_include`, set the following in your Apache.

```
allow_url_fopen = On  
allow_url_include = On
```

These are only required for the file inclusion labs so unless you want to play with those, you

Create / Reset Database

Pagina di login DVWA.



The screenshot shows a web browser window with the title "Login :: Damn Vulnerable Web Application". The address bar displays "http://127.0.0.1/DVWA/login.php". The browser's bookmark bar includes "Import bookmarks...", "OffSec", "Kali Linux", "Kali Tools", "Kali Docs", and "Kali Forums". The main content area features the DVWA logo, which consists of the letters "DVWA" in a bold, dark font, with a green and grey swoosh graphic behind them. Below the logo are two input fields: "Username" and "Password". A "Login" button is positioned below the password field. At the bottom of the page, there is a link that reads "Damn Vulnerable Web Application (DVWA)".

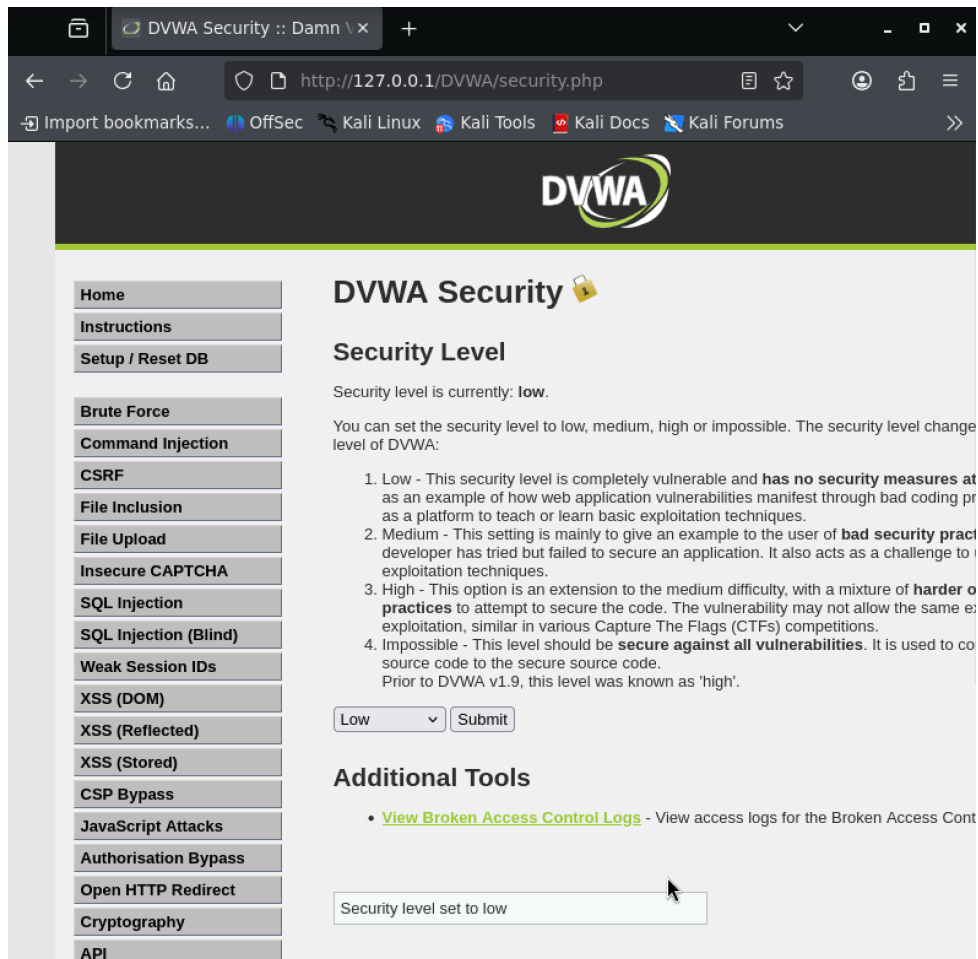
Username

Password

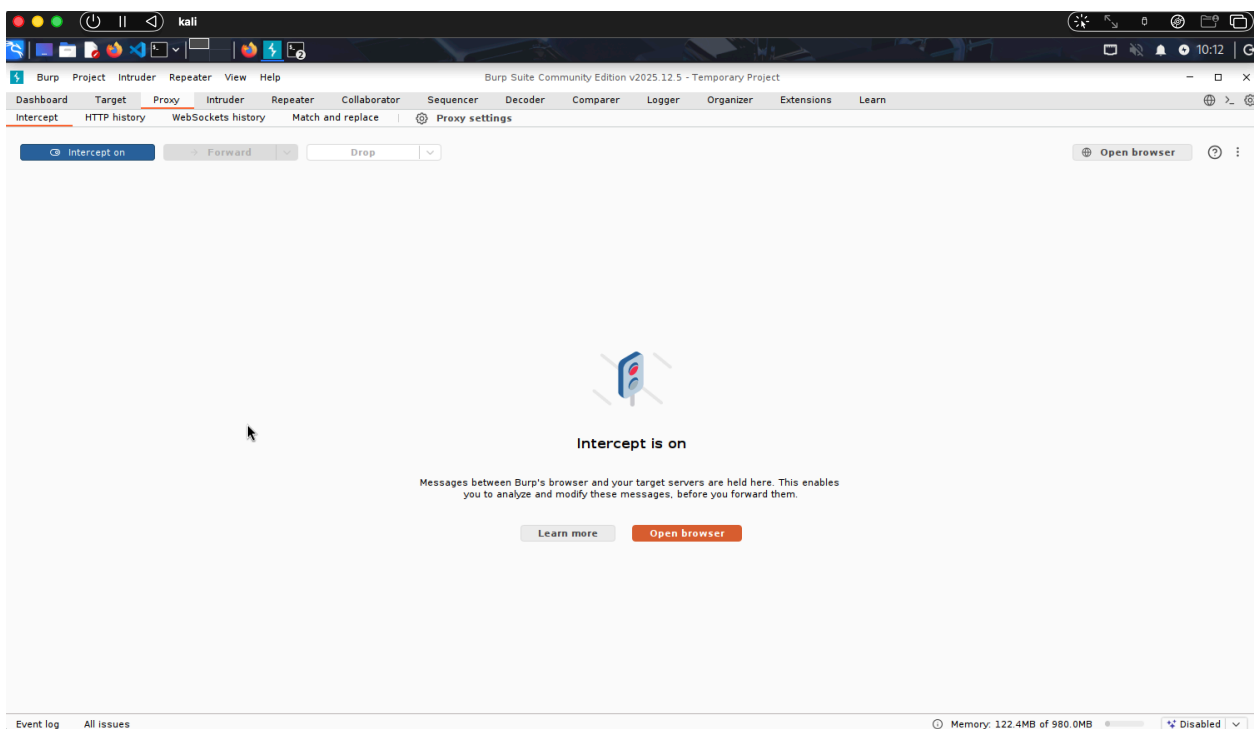
Login

[Damn Vulnerable Web Application \(DVWA\)](#)

Impostazione del livello di sicurezza su LOW.



Burp Suite con Intercept ON.



HTTP history con richiesta di login.

The screenshot shows the Burp Suite interface with the 'HTTP history' tab selected. The history table lists several requests, with the one to `/DWA/login.php` highlighted. The details view on the right shows the request and response for this login attempt.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port
1	https://www.google.com	GET	/warmup.html			404	1782	HTML	html	Error 404 (Not Found)		✓	142.251.155.119		10:12:44.1...	8080
2	https://www.google.com	GET	/warmup.html			404	1782	HTML	html	Error 404 (Not Found)		✓	142.251.155.119		10:13:09.1...	8080
3	http://127.0.0.1	GET	/DWA/login.php			200	1670	HTML	php	Login :: Damn Vulne...			127.0.0.1		10:13:21.1...	8080
7	http://127.0.0.1	POST	/DWA/login.php		✓	302	482	HTML	php				127.0.0.1	PHPSESSID=63...	10:13:31.1...	8080
8	http://127.0.0.1	GET	/DWA/index.php			200	6857	HTML	php	Welcome :: Damn Vu...		✓	127.0.0.1		10:13:31.1...	8080
14	https://www.google.com	GET	/warmup.html					HTML	html			✓	142.251.155.119		10:13:47.1...	8080

Request Details:

```
1 POST /DWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 Content-Length: 88
4 Cache-Control: max-age=0
5 sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Origin: http://127.0.0.1
10 Content-Type: application/x-www-form-urlencoded
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: http://127.0.0.1/DWA/login.php
19 Accept-Encoding: gzip, deflate, br
20 Cookie: security=impossible; PHPSESSID=4bc0bb7a283273f537b9d000deda0955
21
```

Response Details:

```
1 HTTP/1.1 302 Found
2 Date: Wed, 11 Feb 2026 16:13:31 GMT
3 Server: Apache/2.4.66 (Debian)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 Set-Cookie: PHPSESSID=63cc7de7865539d467ccad38f539bcb2; expires=Thu, 12 Feb 2026 16:13:31 GMT; Max-Age=86400; path=/; HttpOnly; SameSite=Strict
8 Location: index.php
9 Content-Length: 0
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
14
```

Repeater: request con parametri di login.

The screenshot shows the Burp Suite Repeater view. A single request is loaded, which is a POST to `/DWA/login.php` with form-encoded data. The details view on the right shows the request and response for this login attempt.

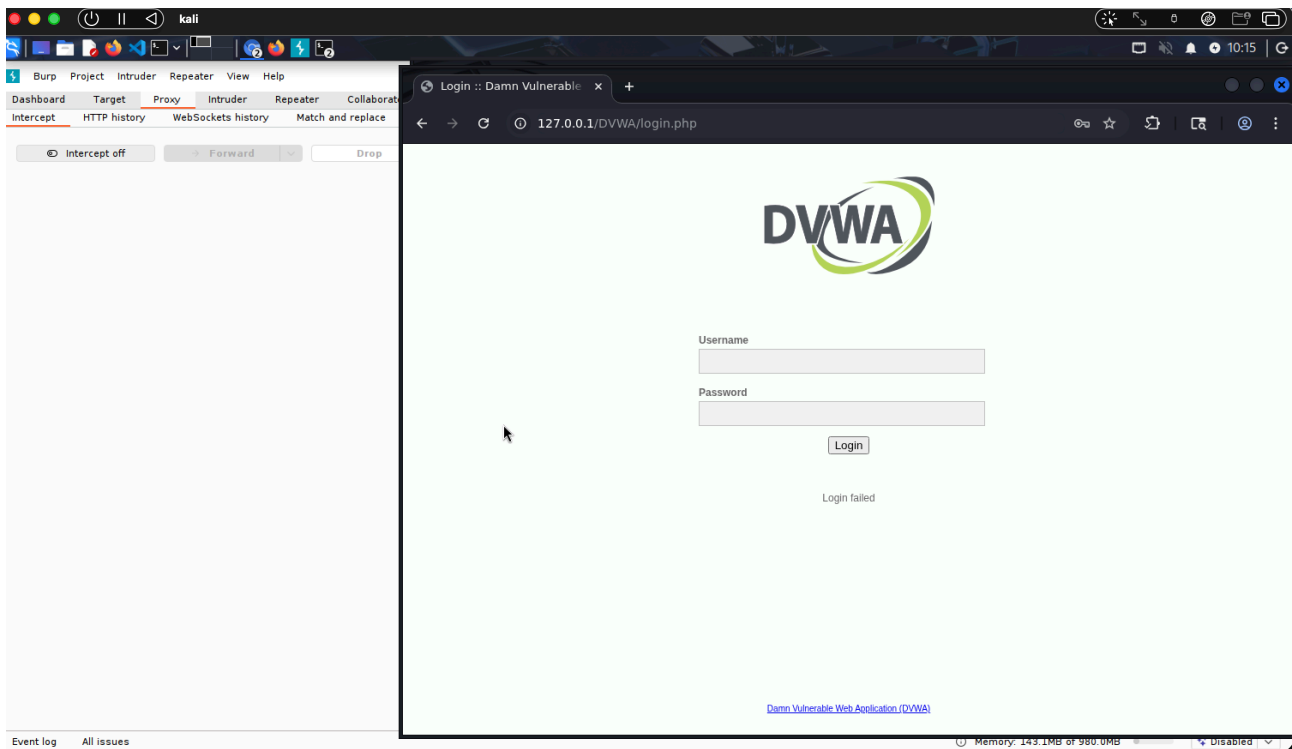
Request Details:

```
1 POST /DWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 Content-Length: 83
4 Cache-Control: max-age=0
5 sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144"
6 sec-ch-ua-mobile: ?0
7 sec-ch-ua-platform: "Linux"
8 Accept-Language: en-US,en;q=0.9
9 Origin: http://127.0.0.1
10 Content-Type: application/x-www-form-urlencoded
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: http://127.0.0.1/DWA/login.php
19 Accept-Encoding: gzip, deflate, br
20 Cookie: security=impossible; PHPSESSID=4bc0bb7a283273f537b9d000deda0955
21
22
23 username=admin&password=nomi&login=Nomi&user_token=34c1f8c651aace0b9f5e11834f41d1b
```

Response Details:

```
1 HTTP/1.1 302 Found
2 Date: Wed, 11 Feb 2026 16:16:53 GMT
3 Server: Apache/2.4.66 (Debian)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 Location: login.php
8 Content-Length: 0
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=UTF-8
12
13
```

Repeater: response con messaggio “Login failed”.



Attività facoltativa – Analisi dei livelli di sicurezza (Medium, High)

Come attività facoltativa è stato ripetuto lo stesso flusso di test modificando esclusivamente il livello di sicurezza dell'applicazione DVWA, passando da Low a Medium e successivamente a High. In tutti i casi, i passaggi operativi (intercettazione della richiesta di login con Burp Suite, analisi della richiesta POST e della response HTTP) rimangono invariati, mentre ciò che cambia è il comportamento dell'applicazione lato server.

Con il livello **Low**, l'applicazione presenta minime misure di protezione e risulta più semplice analizzare i parametri trasmessi e la logica di autenticazione.

Impostando il livello **Medium**, vengono introdotti controlli aggiuntivi che rendono l'analisi leggermente più complessa, pur mantenendo visibile il flusso di autenticazione.

Con il livello **High**, l'applicazione applica ulteriori meccanismi di sicurezza che riducono le informazioni disponibili e rendono più difficile l'analisi diretta delle risposte, dimostrando come l'aumento del livello di sicurezza influisca direttamente sulla superficie di attacco dell'applicazione web. Questa attività

evidenzia come la sicurezza di un'applicazione non dipenda dagli strumenti utilizzati dall'attaccante, ma dalle contromisure implementate lato server.

5. Conclusione

L'esercizio ha dimostrato come Burp Suite possa essere utilizzato per intercettare e analizzare le richieste HTTP di un'applicazione web. In particolare, è stato possibile osservare il flusso di autenticazione di DVWA, identificare i parametri sensibili trasmessi in una richiesta POST e analizzare la risposta del server in caso di credenziali errate. Questa attività rappresenta una base fondamentale per comprendere test di sicurezza più avanzati sulle web application.

L'attività **facoltativa** ha permesso di osservare come la modifica del livello di sicurezza dell'applicazione (**Low, Medium, High**) non cambi il flusso operativo dell'attaccante, ma influisca direttamente sulla quantità di informazioni ottenibili e sulla complessità dell'analisi. Questo confronto evidenzia come l'aumento delle misure di sicurezza lato server riduca la superficie di attacco e renda più difficile l'analisi delle richieste e delle risposte HTTP, sottolineando l'importanza della corretta **FEATURES DI SICUREZZA** nella progettazione di applicazioni web.